

Setup del Laboratorio di Analisi Malware e Identificazione degli Indicatori di Compromissione (IOC)

Relazione di Laboratorio — Attività di Ethical Hacking e Malware Analysis

Ambiente di lavoro: macchina virtuale FlareVM (Oracle VirtualBox, ambiente isolato e controllato)

Campione analizzato in dettaglio: WannaCry.exe

Tipologia di attività: setup laboratorio, hashing, triage VirusTotal, analisi statica, simulazione di persistenza

1. Introduzione

Nell'ambito delle attività didattiche relative alla disciplina della sicurezza informatica, è stata condotta un'esercitazione di laboratorio finalizzata alla configurazione di un ambiente dedicato all'analisi di malware e alla successiva identificazione di Indicatori di Compromissione (IOC) mediante l'esame del Registro di sistema di Windows e il triage di un campione tramite la piattaforma VirusTotal. L'ambiente impiegato è costituito da FlareVM, distribuzione Windows specificamente configurata per il reverse engineering e la malware analysis, eseguita all'interno di una macchina virtuale gestita tramite Oracle VirtualBox.

2. Obiettivi dell'Attività

Coerentemente con quanto stabilito dalla consegna dell'esercizio, l'attività si è posta i seguenti obiettivi specifici:

- Configurare correttamente l'ambiente FlareVM, predisponendo uno snapshot "Clean" pronto all'uso e avviando lo script di popolamento del repository dei campioni (malwareRepo.ps1);
- Identificare gli Indicatori di Compromissione (IOC) associati a un campione malevolo, mediante l'analisi del Registro di Windows e il triage su VirusTotal;
- Simulare, a titolo dimostrativo, la creazione di una chiave di persistenza manuale nel ramo HKCU\...\Run del Registro di sistema, verificandone l'effetto a un successivo accesso (attività bonus);
- Calcolare i valori di hash crittografico dei campioni presenti nella cartella dei malware, quale operazione propedeutica alla loro identificazione univoca;
- Effettuare una ricerca su VirusTotal degli hash calcolati, analizzandone il detection ratio e le schede Behavior e Relations;
- Compilare una tabella riepilogativa degli IOC (hash, domini di comando e controllo, chiavi di registro) individuati nei report di VirusTotal;
- Analizzare, con il supporto di un modello linguistico di intelligenza artificiale, i risultati della ricerca condotta, valutandone criticamente la completezza e l'affidabilità.

3. Metodologia e Ambiente di Laboratorio

La metodologia adottata ha seguito un approccio strutturato, tipico delle attività di predisposizione e utilizzo di un laboratorio di malware analysis, articolato secondo le seguenti fasi operative:

1. Predisposizione dell'ambiente virtualizzato, mediante l'impiego di una macchina virtuale FlareVM eseguita in Oracle VirtualBox, configurata quale ambiente isolato e privo di connessione a reti di produzione;
2. Creazione di uno snapshot "Clean" della macchina virtuale, condizione essenziale per garantire la ripetibilità dell'esercitazione e la possibilità di ripristinare rapidamente uno stato non compromesso del sistema;

3. Avvio dello script malwareRepo.ps1, presente sul Desktop della macchina virtuale, finalizzato al popolamento controllato del repository locale dei campioni da analizzare;
4. Simulazione dimostrativa di persistenza, mediante creazione manuale di una voce nel ramo di registro HKCU\Software\Microsoft\Windows\CurrentVersion\Run;
5. Estrazione e hashing dei campioni, mediante decompressione degli archivi presenti nella cartella "Malware" e calcolo dei valori di hash;
6. Interrogazione della piattaforma VirusTotal, per la raccolta di riscontri incrociati da parte di molteplici motori antivirus e per l'esame delle schede Detection, Details, Behavior e Relations;
7. Analisi statica approfondita tramite lo strumento PESTudio, per l'esame dettagliato della struttura del file eseguibile, delle sezioni, delle librerie importate e delle risorse incorporate;
8. Sintesi degli Indicatori di Compromissione in forma tabellare e valutazione critica, con supporto di intelligenza artificiale, della completezza delle informazioni raccolte.

Si evidenzia come, in coerenza con le buone prassi di sicurezza operativa, il campione ransomware oggetto di analisi non sia mai stato eseguito nel corso dell'attività: l'intera indagine ha carattere esclusivamente statico e di intelligence, condotta senza attivazione del codice malevolo, in un ambiente privo di accesso alla rete locale del calcolatore fisico ospitante, così da prevenire qualsiasi rischio di propagazione accidentale.

4. Fase 1 — Predisposizione dell'Ambiente e Snapshot "Clean"

Come primo passo dell'attività, è stata verificata la disponibilità, sul Desktop della macchina virtuale FlareVM, degli strumenti e degli script necessari all'esercitazione, tra cui lo script di popolamento malwareRepo.ps1, la cartella "Malware" contenente i campioni da analizzare e la cartella "PS_Transcripts", nonché un insieme di strumenti di analisi preinstallati (Visual Studio Code, Wireshark, un client Chrome, un terminale e diversi tool della suite Sysinternals).

Figura 1 — Ambiente desktop della macchina virtuale FlareVM (Oracle VirtualBox, snapshot "Running"), con evidenza delle icone della cartella "Malware", dello script malwareRepo.ps1 e degli strumenti di analisi disponibili.

La creazione dello snapshot "Clean" costituisce una misura di sicurezza operativa imprescindibile nell'ambito della malware analysis: essa consente infatti di riportare l'ambiente virtuale a uno stato integro e non compromesso in tempi rapidi, qualora l'esecuzione — anche accidentale — di un campione dovesse alterare la configurazione del sistema operativo o comprometterne l'integrità.

5. Fase 2 — Simulazione di Persistenza Manuale (Attività Bonus)

Al fine di comprendere empiricamente uno dei meccanismi di persistenza più comunemente sfruttati dal malware — la scrittura di una voce di avvio automatico nel Registro di Windows — si è proceduto alla simulazione manuale di tale tecnica, in assenza di qualsiasi codice malevolo, agendo direttamente sull'Editor del Registro di sistema (regedit).

Figura 2 — Finestra di dialogo "Esegui" utilizzata per l'avvio dell'Editor del Registro di sistema tramite il comando regedit.

Figura 3 — Vista iniziale dell'Editor del Registro di sistema, con evidenza dei cinque hive principali (HKEY_CLASSES_ROOT, HKEY_CURRENT_USER, HKEY_LOCAL_MACHINE, HKEY_USERS, HKEY_CURRENT_CONFIG).

Si è quindi effettuata la navigazione fino al percorso HKEY_CURRENT_USER\SOFTWARE\Microsoft\Windows\CurrentVersion\Run, chiave notoriamente impiegata dal sistema operativo per l'avvio automatico delle applicazioni all'accesso dell'utente, e nella quale risultava già presente, in condizioni normali, un'unica voce legittima (ZoomIt, associata allo strumento Sysinternals ZoomIt64.exe).

Figura 4 — Stato iniziale della chiave di registro HKCU\...\CurrentVersion\Run, precedente alla simulazione, con evidenza dell'unica voce legittima preesistente ("ZoomIt").

Successivamente, è stata creata manualmente una nuova voce di tipo REG_SZ, denominata Test, con valore C:\Windows\System32\calc.exe, in analogia con quanto tipicamente effettuato da un malware per ottenere l'esecuzione automatica di un proprio payload a ogni accesso dell'utente.

Figura 5 — Chiave di registro HKCU\...\CurrentVersion\Run a seguito della creazione manuale della voce di persistenza "Test", con valore C:\Windows\System32\calc.exe.

Al fine di verificarne l'effetto, si è proceduto a un nuovo accesso alla sessione utente, riscontrando l'avvio automatico dell'applicazione Calcolatrice di Windows, a conferma dell'efficacia del meccanismo di persistenza simulato.

Figura 6 — Desktop della macchina virtuale FlareVM al successivo accesso, con l'applicazione Calcolatrice avviata automaticamente in conseguenza della voce di persistenza precedentemente creata nella chiave Run, a riprova dell'efficacia del meccanismo dimostrato.

Tale dimostrazione, sebbene condotta con un'applicazione del tutto innocua (calc.exe), riproduce fedelmente il comportamento tipico dei malware dotati di capacità di persistenza, i quali sostituiscono l'eseguibile legittimo con il proprio payload, garantendosi così l'esecuzione automatica a ogni successivo avvio del sistema o accesso dell'utente, senza necessità di ulteriori interazioni da parte dell'attaccante.

6. Fase 3 — Identificazione e Hashing del Campione

A seguito della decompressione dei campioni presenti nella cartella "Malware\Ransomware" del repository locale, è stato individuato il file WannaCry.exe, riconducibile alla nota famiglia di ransomware che ha causato un incidente di sicurezza informatica di portata globale nel maggio 2017. Si è proceduto al calcolo dei relativi valori di hash crittografico mediante la funzionalità integrata dello strumento di analisi, operazione indispensabile ai fini dell'identificazione univoca del file e della successiva interrogazione delle banche dati di threat intelligence.

Tabella 1 — Valori identificativi del campione

Proprietà	Valore
Nome file	WannaCry.exe
MD5	5c7fb0927db37372da25f270708103a2
SHA-1	120ed9279d85cbfa56e5b7779ffa7162074f7a29
CRC32	02ac7126
SHA-256	be22645c61949ad6a077373a7d6cd85e3fae44315632f161adc4c99d5a8e6844
Percorso completo	C:\Users\FlareVm\Desktop\Malware\Ransomware\WannaCry.exe
Dimensione	229.376 byte (224,00 KB)
Data di modifica	21/05/2025 07:46:10
Data di creazione (sistema di analisi)	04/08/2026 08:19:32
Versione file dichiarata	6.1.7600.16385 [win7_rtm.090713-1255]
Versione prodotto dichiarata	6.1.7600.16385

Figura 7 — Finestra delle proprietà estese del file WannaCry.exe, riportante l'insieme completo dei valori di hash (MD5, SHA-1, CRC32, SHA-256, SHA-384, SHA-512), il percorso completo e i metadati di versione.

Si osserva, quale prima incongruenza rilevata, come la versione dichiarata dal file (6.1.7600.16385, corrispondente a Windows 7 RTM) risulti palesemente incompatibile con l'anno di rilascio pubblico del ransomware WannaCry (2017): tale discrepanza, unitamente alla marca temporale di modifica riportata (2025), costituisce un primo indizio della natura non genuina dei metadati del file, riconducibile a un tentativo di occultamento (tecnica di masquerading, MITRE ATT&CK T1036) piuttosto che a un errore di sistema.

7. Fase 4 — Analisi di Intelligence Collettiva (VirusTotal)

Il valore di hash SHA-256 calcolato nella fase precedente è stato sottoposto alla piattaforma VirusTotal, ai fini della verifica della reputazione del campione presso la comunità internazionale di sicurezza e dell'esame delle schede Detection, Details e Behavior.

Figura 8 — Sintesi del responso di VirusTotal per il campione WannaCry.exe: 60 motori antivirus su 66 lo hanno classificato come malevolo, con etichetta di minaccia popolare "trojan.wannacryptor/wanna".

Il campione ha ottenuto un tasso di rilevamento pari a 60 rilevamenti su 66 motori antivirus interrogati, valore che rappresenta un indicatore di elevatissima attendibilità circa la natura malevola del file. La piattaforma ha attribuito al campione l'etichetta di minaccia popolare trojan.wannacryptor/wanna, classificandolo nelle categorie "trojan" e "ransomware" e associandolo alle famiglie wannacryptor, wanna e wannacry. La quasi totalità dei fornitori di sicurezza interrogati (tra cui AhnLab-V3, BitDefender, ESET-NOD32, F-Secure, Fortinet e GData) ha restituito un'etichetta esplicitamente riconducibile a "WannaCryptor" o "WannaCry", confermando l'assenza di ambiguità nella classificazione della minaccia.

Di particolare interesse, ai fini dell'identificazione degli IOC comportamentali, risulta l'insieme dei tag associati al campione dalla piattaforma: persistence, long-sleeps, calls-wmi, checks-user-input, checks-cpu-name, direct-cpu-clock-access e detect-debug-environment. Tali indicatori comportamentali suggeriscono, rispettivamente, la capacità del malware di persistere nel sistema, l'adozione di tecniche di temporizzazione dilatoria finalizzate a eludere l'analisi automatizzata in ambienti sandbox (long-sleeps), l'impiego dell'infrastruttura Windows Management Instrumentation per la raccolta di informazioni di sistema, nonché diverse tecniche di rilevamento dell'ambiente di analisi e di anti-debugging.

Figura 9 — Scheda dei metadati tecnici estesi del campione su VirusTotal (tab Details), con hash di similarità (imphash, ssdeep, TLSH), tipo di compilatore (Microsoft Visual C/C++ 6.0) e indicazione della presenza di un archivio ZIP cifrato incorporato (Archive: Zip 2.0, encrypted, 44,8%).

Il dato relativo alla presenza di un archivio ZIP cifrato incorporato nel file, rilevato dallo strumento DetectItEasy integrato in VirusTotal, costituisce un elemento di particolare rilievo, in quanto anticipa quanto successivamente confermato in sede di analisi statica approfondita, ovvero l'esistenza di un payload secondario incorporato e protetto da cifratura, tipico modus operandi del ransomware WannaCry per l'occultamento dei propri componenti.

8. Fase 5 — Analisi Statica Approfondita (PEStudio)

Al fine di completare il quadro informativo raccolto, si è proceduto a un'analisi statica di maggior dettaglio mediante lo strumento PEStudio.

Figura 10 — Panoramica generale del file in PEStudio: dimensione, entropia complessiva (7,644 su 8), punto di ingresso, descrizione interna del file ("dvdplay placeholder Application") e marca temporale del compilatore.

Dall'analisi generale del file sono emersi i seguenti elementi di rilievo:

- Entropia complessiva del file: 7,644 (su una scala massima di 8), valore estremamente elevato e fortemente indicativo della presenza di dati cifrati o compressi in misura significativa;
- Descrizione interna del file: "dvdplay placeholder Application", incoerente con la reale funzionalità del programma;
- Nome originale del modulo (campo original-file-name): dvdplay, ulteriore conferma della strategia di masquerading adottata;
- Marca temporale di compilazione: martedì 14 luglio 2009, dato incompatibile con l'anno di prima diffusione pubblica del ransomware (2017);
- Punteggio VirusTotal integrato: 60/66, coerente con quanto rilevato in sede di interrogazione diretta della piattaforma.

Figura 11 — Elenco dettagliato dei responsi dei singoli motori antivirus, come integrato nello strumento PEStudio, con relative etichette di rilevamento e date di ultima analisi.

L'esame della struttura interna del file ha permesso di individuare quattro sezioni (.text, .rdata, .data, .rsrc), i cui valori di entropia sono riportati nella tabella seguente.

Tabella 2 — Sezioni del file eseguibile e relativa descrizione tecnica

Sezione	Entropia	Caratteristiche	Descrizione tecnica
.text	6,111	Esecuzione	Contiene il codice macchina eseguibile del programma. Il valore di entropia, superiore alla media attesa per codice non compresso, è compatibile con la presenza di routine parzialmente offuscate.
.rdata	6,546	Lettura	Sezione dei dati di sola lettura (stringhe costanti, tabella degli import). Il valore di entropia, anch'esso superiore alla norma, può derivare dalla presenza di stringhe cifrate o codificate.
.data	4,096	Lettura/Scrittura	Sezione delle variabili globali e statiche inizializzate; il valore è coerente con la natura ordinariamente non compressa di tale sezione.
.rsrc	7,993	Lettura	Sezione delle risorse. Il valore, pressoché al massimo teorico (8), costituisce un indicatore di massima gravità, compatibile con l'incorporamento di un archivio cifrato/compresso.

Figura 12 — Tabella delle sezioni del file PE in PESTudio, con evidenza del valore di entropia critico (7,993) associato alla sezione .rsrc.

L'esame della tabella degli import ha rilevato un totale di 87 funzioni importate, di cui 10 espressamente segnalate come sospette, distribuite tra le librerie KERNEL32.dll, ADVAPI32.dll e WS2_32.dll. Le funzioni contrassegnate come critiche includono VirtualAlloc e VirtualProtect (allocazione di memoria e modifica dei permessi di esecuzione), CreateDirectoryA e WriteFile (creazione di directory e scrittura di file su disco, coerenti con l'attività di cifratura tipica del ransomware), nonché l'intero gruppo di funzioni crittografiche CryptAcquireContextA, CryptImportKey, CryptDecrypt, CryptReleaseContext e CryptDestroyKey, riconducibili in modo inequivocabile alle operazioni di gestione delle chiavi e di cifratura/decifratura tipiche del funzionamento di un ransomware. Risulta inoltre segnalata la funzione inet_addr, importata dalla libreria WS2_32.dll, indicativa della presenza di funzionalità di comunicazione di rete.

Figura 13 — Tabella degli import del file in PESTudio, con evidenza delle 10 funzioni segnalate come sospette, tra cui l'insieme delle funzioni crittografiche (Crypt) e la funzione di rete inet_addr (libreria WS2_32.dll).*

Da ultimo, l'analisi della sezione delle risorse ha confermato quanto anticipato dalla scheda Details di VirusTotal: è stata individuata una risorsa di tipo SMD (105 istanze) recante la firma "PKZIP-Self Extractor", di dimensione pari a 160.287 byte ed entropia pari a 7,998, valore prossimo al massimo teorico e fortemente indicativo della presenza di un archivio compresso e cifrato incorporato nell'eseguibile.

Figura 14 — Scheda delle risorse del file in PESTudio, con evidenza della risorsa "PKZIP-Self Extractor" (entropia 7,998), corrispondente al payload secondario incorporato e cifrato, tipico del pacchetto di distribuzione del ransomware WannaCry.

Tale riscontro conferma il modus operandi noto del ransomware WannaCry, che incorpora al proprio interno un archivio compresso protetto da password, contenente i componenti ausiliari necessari al proprio funzionamento, estratti ed eseguiti solo al momento dell'attivazione del payload principale.

9. Tabella degli Indicatori di Compromissione (IOC)

Sulla base delle evidenze raccolte nel corso delle fasi precedenti, è stata compilata la seguente tabella riepilogativa degli Indicatori di Compromissione, distinta per tipologia.

Tabella 3 — Indicatori di Compromissione identificati

Tipologia IOC	Valore	Fonte / Riscontro
Hash MD5	5c7fb0927db37372da25f270708103a2	Proprietà del file (Figura 7)
Hash SHA-1	120ed9279d85cbfa56e5b7779ffa716207af7a29	Proprietà del file (Figura 7)
Hash SHA-256	be22645c61949ad6a077373a7d6cd85e3fae44315632f161adc4c99d5a8e6844	Proprietà del file / query VirusTotal (Figure 7–8)
Imphash	e858a14f217810d78466806d95d7fceb	VirusTotal — tab Details (Figura 9)
Nome file originale (masquerading)	dvdplay	PEStudio — campo original-file-name (Figura 10)
Chiave di registro di persistenza (dimostrazione)	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\Test	Simulazione manuale (Figure 4–5)
Tag comportamentali VirusTotal	persistence, long-sleeps, calls-wmi, checks-user-input, checks-cpu-name, direct-cpu-clock-access, detect-debug-environment	VirusTotal — riepilogo (Figura 8)
Dominio noto associato alla campagna (kill-switch)	www.iuqerfsodp9ifjaposdfjhgosurijfaewrgwea[.]com	Informazione di dominio pubblico, non riscontrata direttamente negli screenshot — riportata a titolo di contestualizzazione storica
Vulnerabilità sfruttata (nota storicamente)	MS17-010 / EternalBlue (SMBv1)	Informazione di dominio pubblico, non oggetto di verifica diretta nel presente laboratorio

Si segnala, con onestà metodologica, come le schede Relations e Behavior di VirusTotal — la cui consultazione era prevista dalla consegna dell'esercizio ai fini dell'identificazione di eventuali domini di comando e controllo aggiuntivi e di ulteriori chiavi di registro — non siano state oggetto di acquisizione documentale (screenshot) nel corso della presente sessione di laboratorio. Le informazioni relative al dominio di kill-switch e alla vulnerabilità EternalBlue sono pertanto riportate quali dati di dominio pubblico, ampiamente documentati dalla letteratura di settore relativa all'incidente WannaCry del 2017, e non quali riscontri diretti ottenuti dalle schede in questione durante l'esercitazione. Si raccomanda, in sede di eventuale ripetizione o approfondimento dell'attività, di completare la consultazione delle citate schede al fine di arricchire la tabella IOC con riscontri di prima mano.

10. Valutazione del Supporto dell'Intelligenza Artificiale nell'Analisi

Coerentemente con quanto richiesto dalla consegna dell'esercizio, i risultati raccolti nelle fasi precedenti sono stati sottoposti a un modello linguistico di intelligenza artificiale, al fine di ottenerne un'interpretazione tecnica di sintesi e di valutarne criticamente la completezza.

Dall'analisi condotta è emerso come il modello sia stato in grado di:

- correlare correttamente i molteplici riscontri provenienti da strumenti diversi (proprietà del file, VirusTotal, PESTudio) in un quadro interpretativo coerente, giungendo a una classificazione della minaccia (trojan ransomware della famiglia WannaCry) pienamente allineata con il verdetto della comunità antivirus;
- identificare correttamente il significato tecnico delle singole funzioni importate segnalate come sospette (in particolare il gruppo di funzioni crittografiche Crypt* e le funzioni di gestione della memoria VirtualAlloc/VirtualProtect), fornendo una spiegazione accessibile anche a un analista non esperto;
- fornire indicazioni operative concrete in merito alle azioni di contenimento da adottare in caso di reale infezione (isolamento della rete, non esecuzione del file, scansione del sistema, verifica della persistenza, cambio delle credenziali).

Si segnalano, per converso, alcuni limiti riscontrati nella risposta del modello, coerenti con le criticità generalmente note dell'impiego di sistemi di intelligenza artificiale generativa in ambito tecnico-forense:

- assenza di verifica autonoma delle fonti: il modello non è stato in grado di consultare autonomamente le schede Relations e Behavior di VirusTotal, limitandosi a elaborare le informazioni fornite in input dall'analista;
- assenza di contestualizzazione temporale automatica: il modello non ha segnalato in autonomia l'incongruenza tra le marche temporali di compilazione/modifica del file e la data di prima diffusione pubblica del ransomware, elemento evidenziato manualmente dall'analista;
- necessità di validazione umana: le informazioni di dominio pubblico richiamate dal modello risultano corrette e ben note in letteratura, ma non derivano da un riscontro diretto nei dati raccolti nel laboratorio.

In conclusione, il supporto del modello linguistico si è rivelato efficace come strumento di sintesi e di interpretazione tecnica di secondo livello, in grado di accelerare significativamente la comprensione dei riscontri raccolti dall'analista, ma non sostitutivo del giudizio critico e della verifica diretta delle fonti primarie, che restano di esclusiva competenza dell'analista umano.

11. Conclusioni

L'attività di laboratorio condotta ha consentito di raggiungere pienamente gli obiettivi didattici prefissati, dimostrando come la predisposizione rigorosa di un ambiente di analisi isolato e ripristinabile, unita all'applicazione di una metodologia strutturata di triage e analisi statica, sia in grado di produrre un quadro informativo completo e affidabile circa la natura di una minaccia

informatica, senza necessità di eseguirne il codice e senza esporre l'ambiente di lavoro ad alcun rischio concreto.

Il campione analizzato rappresenta un caso di studio di primaria importanza nella storia della sicurezza informatica, la cui analisi consente di comprendere in concreto le dinamiche tecniche — propagazione automatica, cifratura dei dati, persistenza, evasione dai sistemi di rilevamento — che continuano a caratterizzare, seppur con crescente sofisticazione, le più recenti campagne ransomware. L'esercitazione conferma, ancora una volta, come la sicurezza informatica debba essere concepita quale processo continuo e multilivello, fondato sull'integrazione sinergica di misure tecniche, misure organizzative e un costante affinamento delle competenze analitiche del personale addetto alla sicurezza, eventualmente coadiuvato — ma mai sostituito — da strumenti di intelligenza artificiale.

L'esperienza maturata nel corso della presente esercitazione costituisce, in tal senso, un contributo formativo di rilievo per lo sviluppo delle competenze professionali richieste nell'ambito della cybersecurity, in piena aderenza ai principi etici e metodologici propri della disciplina dell'ethical hacking.

La presente relazione è stata redatta esclusivamente per finalità didattiche e di formazione accademica, nell'ambito di un'attività di laboratorio condotta in ambiente virtualizzato, isolato e controllato. Nessuna delle operazioni descritte è stata eseguita al di fuori di tale ambiente, né ha comportato l'esecuzione del codice ransomware analizzato.